# Printix MCP — GDPR Compliance Guide

# Printix MCP — GDPR Compliance Guide

**A guide to roles, scopes, and the data-protection posture of the Printix MCP server**

Version: aligned with Printix MCP v7.2.24 Document date: April 2026 Audience: Customer DPO, IT Security, Procurement, Compliance Reviewers

---

## Executive Summary

The Printix MCP server is a self-hosted bridge between Printix and AI assistants such as Claude.ai, ChatGPT, and Microsoft Copilot. It runs on the customer's own infrastructure, uses the customer's existing Printix credentials, and never forwards print metadata to any third party other than the AI assistant the user has explicitly chosen.

This guide describes the access-control model, the audit posture, and the GDPR articles directly addressed by the implementation.

---

## 1. Deployment Model

The Printix MCP server is delivered as a Docker container that runs on the customer's premises (or in a customer-owned cloud environment).

The implications for GDPR are direct and meaningful:

- **Print metadata never leaves the customer tenant.** The MCP server acts on behalf of the customer's Printix tenant; data flows from Printix to the customer-hosted MCP server and from there only to the AI assistant the user is authenticated with.
- **Tungsten Automation is not a data processor.** Because the runtime is operated by the customer, no separate Article 28 data-processing agreement is required between the customer and Tungsten for the metadata that flows through the MCP server. The customer's existing Printix-tenant agreement and AI-assistant-vendor agreement are the controlling contracts.
- **Air-gap-friendly.** When the customer's Printix tenant is reachable from the host but no AI assistant is configured, the MCP server is fully functional for internal automation use without any external data flow.

---

## 2. The Five Roles

Every authenticated user is assigned one of five MCP roles. The role determines which tools the user (or the user's AI assistant) is permitted to invoke.

| Role | Purpose | GDPR reference |
|---|---|---|
| **End User** | Standard employee. Can print own jobs, see own quota, register own card. Cannot view other users' data. | Art. 5(1)(c) data minimisation; Art. 15-22 data subject rights |
| **Helpdesk** | Support function. Diagnose other users, reset cards, reassign jobs, read reports. Cannot delete users, modify infrastructure, or trigger backups. | Art. 32 — separation of duties |
| **Admin** | Tenant administrator. Full create/read/update/delete authority across users, sites, networks, cards, reports, capture profiles, backups. | Art. 24 — controller obligations |
| **Auditor (DPO)** | Compliance and data-protection function. Read-only access to the audit log, reports, and the user list. No print actions, no mutations, no card data. | Art. 37–39 — Data Protection Officer |
| **Service Account** | Headless automation token (capture callbacks, scheduled reports, integrations). Permitted scopes are whitelisted explicitly per token. Not a human user; cannot log in to the web interface. | Art. 28 — processor; Art. 32 — accountability |

Auditor and Service Account are explicit-only roles: they are assigned per individual user/token, not via Printix groups. This matches the real-world pattern that the DPO is named individually under GDPR Art. 37 and that service accounts are not members of organisational groups.

---

# 3. How Roles Are Assigned

The administrator manages roles on the page **`/admin/mcp-permissions`**. Two independent paths combine to determine the effective role of any user at runtime.

## 3.1 Per-User Override

The administrator can set an explicit role for any individual user. Explicit overrides take precedence over any group-derived role. This is the right tool for individuals (the DPO, key administrators, named helpdesk staff) and for service-account tokens.

## 3.2 Per-Printix-Group Default

The administrator can assign an MCP role to any Printix group. All members of that group automatically inherit the role unless they have an explicit override.

When a user is a member of multiple groups with different role assignments, the **highest role wins**. The order is:

```
End User (1)  <  Helpdesk (2)  <  Admin (3)
```

A user in both *Marketing* (End User) and *IT-Support* (Helpdesk) is therefore resolved as Helpdesk.

### 3.3 Default

Users with neither an explicit override nor any group-derived role are treated as **End User**. This is the safe default: no access to other users' data, no ability to modify the system.

---

## 4. Permission Scopes

Each tool that the MCP server exposes is tagged with exactly one permission scope. The role-to-scope matrix decides which roles can invoke which scopes.

| Scope | Description | Allowed roles |
|---|---|---|
| `mcp:self` | Operations on the caller's own data only — print own jobs, look up own status, ask self-introspection questions | All authenticated users |
| `mcp:read` | Read-only operations across the tenant — list printers, get job details, run reports, diagnose users | Helpdesk, Admin, Auditor |
| `mcp:audit` | Read access to the structured audit log | Admin, Auditor |
| `mcp:write` | Create / update / delete operations — manage users, sites, networks, cards, schedules | Admin |
| `mcp:system` | Administrative operations — backups, demo data, time-bomb engine, system commands | Admin |

When enforcement is active, every tool call is checked against this matrix at runtime. Calls outside the caller's scope return a structured `permission_denied` response and are recorded in the audit log.

The administrator can verify the effective scope of any user by asking the user's AI assistant to invoke `printix_my_role`, which returns the resolved role, the permitted scopes, and counts of allowed/denied tools for transparency.

---

## 5. Data Subject Rights — built-in tools

Every authenticated user can exercise their GDPR rights without filing a paper form. Two MCP tools turn the legal procedure into a single conversation with the AI assistant:

### `printix_personal_data_export` — Article 15 (right of access)

When a user asks their AI assistant *"What data do you have about me?"*, the tool gathers everything the MCP server holds:

- The Printix user profile
- Group memberships
- All RFID/HID/Mifare cards mapped to the subject
- Audit-log entries authored by the subject (last 500)
- Pending and resolved onboarding time-bombs

- Print statistics for the last 365 days (when SQL reporting is configured)
- The MCP role override, if any

The result is a structured ZIP with one JSON file per category and a README.txt explaining each artefact. Helpdesk and admin roles can generate the same export for any subject in support of formal data-subject access requests; end users are restricted to their own data via a self-check inside the tool.

### `printix_personal_data_purge_request` — Article 17 (right to erasure)

A non-destructive request channel. The tool:

1. Compiles the same data summary the export tool produces
2. Records the request in the audit log with `action='gdpr_purge_requested'` and a unique request ID
3. Sends a structured HTML email to the configured tenant administrators with the summary, the requester's identity, and the optional reason
4. Returns the request ID and the list of notified administrators to the requester

The tool **does not delete any data directly.** End users are not authorised to remove records — this prevents malicious self-purge, accidental data loss, and ensures every deletion is traceable to a specific administrator who reviewed the request. The administrator executes deletion through the existing tools (`printix_offboard_user` for soft removal preserving the audit trail, or `printix_delete_user` for full erasure) within the one-month deadline imposed by GDPR Art. 12(3).

## 6. Audit Trail

Every tool invocation, both successful and denied, is recorded in the `audit_log` table with the following fields:

- `user_id` — the calling user
- `tenant_id` — the customer tenant
- `action` — what was attempted (`mcp_<tool>`, `mcp_permission_denied`)
- `object_type` and `object_id` — the entity acted on
- `details` — a human-readable summary
- `created_at` — UTC timestamp

The audit log satisfies GDPR Art. 30 record-of-processing requirements for the MCP layer. It is queryable from the web interface (`/admin/audit`) and through the dedicated MCP tool `printix_query_audit_log`, which is itself scoped to Auditor and Admin.

Denied calls are particularly valuable for ongoing compliance review: they tell the administrator whether the role assignments match the actual usage patterns, and they evidence that access controls are functioning under live load.

---

## 7. GDPR Article Coverage

The implementation directly addresses the following articles. References are to the EU General Data Protection Regulation (Regulation (EU) 2016/679).

| Article | Requirement | Implementation |
|---|---|---|
| **Art. 5(1)(c)** | Data minimisation | End User role limits data access to the user's own records. Helpdesk role excludes card-data scope. Auditor role excludes mutations and print payloads. |

| Article | Requirement | Implementation |
|---|---|---|
| **Art. 5(1)(f)** | Integrity and confidentiality | Encryption at rest (Fernet) for all stored credentials; TLS on all listeners; per-tenant database isolation. |
| **Art. 12(3)** | One-month response window | The `printix_personal_data_purge_request` tool emits a timestamped audit-log entry and an admin notification with all data needed for the controller to respond within the deadline. |
| **Art. 15** | Right of access | `printix_personal_data_export` produces a complete ZIP of the subject's data on demand. End users may export their own data; Helpdesk and Admin may export on behalf of any subject. |
| **Art. 17** | Right to erasure | `printix_personal_data_purge_request` records the deletion request, summarises the affected data, and notifies the administrator. Execution via `printix_offboard_user` / `printix_delete_user` cascades to dependent records. |
| **Art. 24** | Controller obligations | Admin role formalised as the controller-equivalent function. Role assignment is itself audited. |
| **Art. 25** | Privacy by design and default | Customer-hosted runtime with no default external egress. New users default to End User; elevation requires an explicit, audited administrative action. |
| **Art. 28** | Processor relationships | The MCP runtime is operated by the customer; Tungsten is not a processor of the metadata that flows through it. |
| **Art. 30** | Record of processing activities | Structured `audit_log` table records both successful and denied calls with user, action, object, timestamp. |
| **Art. 32** | Technical and organisational measures | Role-based access control with three production roles plus DPO and service-account designations. Token masking in logs, OAuth refresh, PKCE on the mobile flow, TLS in transit, encryption at rest. |
| **Art. 37–39** | Data Protection Officer | Auditor role provides read-only access to audit log and reports without operational privileges, matching the DPO independence requirement. |

## EU AI Act

| Article | Requirement | Implementation |
|---|---|---|
| **Art. 50** | Transparency obligations for AI systems | Every tool carries machine-readable annotations (`readOnlyHint`, `destructiveHint`, `idempotentHint`, `openWorldHint`) so AI assistants can surface explicit confirmation prompts to the user before destructive actions. The published user |

| Article | Requirement | Implementation |
|---|---|---|
| | | manual documents all 125 tools in three languages. |

---

# 8. Operational Controls

Independent of the role model, the MCP server implements the following controls by default. They apply to every deployment regardless of how roles are configured.

## Authentication

- OAuth 2.0 bearer token per user, encrypted at rest with Fernet
- Per-tenant database isolation enforced at the schema level
- Microsoft Entra ID single sign-on supported for desktop and mobile
- Mobile authentication uses Authorization Code Flow with PKCE (RFC 7636)
- Bearer tokens are masked in all log output and never appear in MCP responses

## Transport

- TLS on all listeners (web UI, MCP endpoint, IPP/IPPS)
- Certificate material sourced from the host's `/ssl` directory or the operator's reverse proxy
- DNS-rebinding protection automatically applied when the server is bound to a loopback address

## Configuration

- Print payloads transit the server in memory only — no persistent on-disk store of print content
- Email channel region (Resend EU vs US) is operator-selectable
- Notification preferences are configurable per tenant
- Backup creation is rate-limited and itself audited

## Tool intent metadata

Every one of the 129 production tools carries MCP `ToolAnnotations` that describe its behavioural shape:

- `readOnlyHint` — the tool only reads
- `destructiveHint` — the tool deletes or modifies critical state
- `idempotentHint` — repeated calls have the same effect as one
- `openWorldHint` — the tool calls an external service

AI assistants such as Claude and Microsoft Copilot use these annotations to decide when to surface a confirmation prompt to the user, and to display an appropriate warning before destructive operations.

---

# 9. How to Verify

The following checks confirm the access-control posture in any deployment.

| Check | Where | What you should see |
|---|---|---|
| Status of the role gate | `/admin/mcp-permissions` (top banner) | Green banner "RBAC is active" with `MCP_RBAC_ENABLED=1` chip when enforcement is on |

| Check | Where | What you should see |
|---|---|---|
| Currently assigned roles | `/admin/mcp-permissions` (groups + users sections) | Live Printix groups with role dropdowns; user-override list with explicit overrides where set |
| Effective role for a given user | Ask the user's AI assistant: *"What can I do?"* | A `printix_my_role` response with role, permitted scopes, and counts of allowed/denied tools |
| Audit trail | `/admin/audit` | Chronological list of all MCP actions and denied calls with user, action, object, timestamp |
| Audit trail via API | `printix_query_audit_log` (Auditor or Admin) | Same data, filterable by date, user, action |

When the green RBAC-active banner is displayed, the role assignments on the same page are the live policy: changes take effect immediately and are recorded in the audit log.

---

# 10. Summary

The Printix MCP server provides a defensible, GDPR-aligned access-control posture out of the box:

- **Five roles** mapped directly to GDPR functions
- **Two assignment paths** (per-user and per-Printix-group) for practical day-to-day administration
- **Explicit DPO role** for compliance review independent of operations
- **Structured audit trail** covering both permitted and denied calls
- **Customer-hosted deployment model** that keeps Tungsten outside the data-processor scope for the data flowing through MCP
- **Encryption at rest, TLS in transit, OAuth-with-PKCE for mobile** as the foundational technical measures
- **Tool-intent annotations** that allow AI assistants to surface appropriate confirmation prompts to the user before destructive actions

The model is designed to be auditable: every architectural choice maps back to a specific GDPR article or EU AI Act provision, and every runtime decision is recorded in a queryable log.

---